

PART 5 OF 5

Harness

Interview Question Bank

Enterprise Architect · Platform Engineer · DevSecOps Lead

Synthesized from the architecture, AI-agent, security, and best-practices reports

Research date: July 2026

Each question includes a brief note on what a strong answer actually demonstrates — not a model answer, but the signal to listen for. Level tags: **L1** foundational/screening, **L2** working knowledge, **L3** senior/architect depth.

Enterprise / Platform Architect

1 **L1**

Walk me through why Harness splits into a control plane and a Delegate instead of one monolithic system. What problem does that actually solve?

Listen for: the trust-boundary argument — outbound-only connection, no inbound ports, SaaS control plane can sit outside the network while still reaching air-gapped/regulated infrastructure. A weak answer just says "security"; a strong one explains the pull-based mechanism.

2 **L2**

A business unit wants their own dedicated Delegate fleet instead of using the shared platform pool. When is that the right call, and when is it empire-building?

Listen for: recognition of the three real Delegate patterns (centralized pool, BU-owned, network-isolated) and that the right answer depends on whether the BU already owns infra budget/RBAC independently or has a genuine compliance-isolation requirement — not just organizational preference.

3 **L3**

Design the Delegate topology for a bank with a PCI-segmented cardholder-data environment, a separate air-gapped core-banking data center, and a public-cloud digital-banking front end. Where do trust boundaries fall?

Listen for: at least three isolated Delegate populations mapped to the three environments, explicit denial of raw CLI capability on Delegates with JIT access instead, and an understanding that SLSA Level 3 (ephemeral, Harness-hosted build infra) isn't achievable in the air-gapped zone — a candidate who doesn't flag that constraint hasn't done the diligence.

4 **L3**

How would you decide between Harness and a combination of GitHub Actions + ArgoCD + Backstage for a 5,000-developer organization?

Listen for: a framework, not a verdict — regulatory/audit burden, number of business units needing shared governance, whether the org already has engineering capacity to run/govern Backstage, and whether AI-agent governance is a near-term requirement. A strong candidate names the actual tradeoff (platform consolidation + governance depth vs. best-of-breed + lower per-tool lock-in) rather than declaring a universal winner.

5 L2

What's the difference between Harness's IDP and self-hosting Backstage directly?

Listen for: Harness IDP is built *on* Backstage's catalog model but adds OPA-governed entity policies, self-service workflows that are literal Harness pipelines (inheriting RBAC/audit), and removes the self-hosting/plugin-maintenance burden. Bonus: awareness that a 2026 industry critique argues Backstage's UI-centric architecture is itself a poor fit for agent-native platforms.

6 L3

Your CFO asks why we need both Harness's DORA dashboard and Software Engineering Insights — aren't they the same thing?

Listen for: clear articulation that the CD dashboard is pipeline-scoped (deployment activity only) while SEI correlates 40+ tools via a configurable DORA Profile and a correlation engine that can trace, e.g., long lead time back to GitHub review delays rather than anything in the CD pipeline. A candidate who can't explain the correlation engine's actual value is reciting a feature list, not architecting.

Platform Engineer

1 L1

You've built a pipeline template and three teams are now forking away from it instead of using it. What went wrong?

Listen for: recognition of the "all-or-nothing template" anti-pattern and the fix — govern the seams (mandate that a check runs) rather than locking the whole pipeline into one rigid shape. Bonus for citing the specific pattern: mandate a linter runs, let teams pick which one.

2 L2

How do you prevent template changes from silently breaking every pipeline that references them?

Listen for: versioning discipline — stable version pinning, using the UI to diff versions, bumping to a new version for breaking changes rather than mutating a version in place. A candidate who says "just tell people in Slack" hasn't operated this at scale.

3 L3

Your Delegate pool is intermittently queueing builds under load. Walk me through how you'd diagnose and fix it without just adding more Delegate replicas.

Listen for: distinguishing between Delegate task-scheduling capacity vs. underlying build-infrastructure capacity (ephemeral CI pods/Lite Engine), checking whether it's a single centralized pool serving too many concurrent teams (a documented bottleneck pattern), and considering whether specific teams need isolated Delegate capacity rather than just scaling the shared pool blindly.

4 L2

A team wants to sync raw Helm templates directly via GitOps instead of pre-rendering them. What's your concern?

Listen for: config sprawl — when the GitOps engine renders the final YAML internally, "what's running" only exists inside the reconciler, and drift/debugging across layered overlays becomes a nightmare. Correct answer: render in CI, commit rendered output, sync that.

5 L1

What's the difference between a Policy Set severity of "Warn and Continue" versus "Error and Exit," and when would you use each during a rollout?

Listen for: Warn-and-Continue for baselining/new policies to avoid breaking teams on day one, graduating to Error-and-Exit once adoption is validated — matches the phased rollout approach rather than going straight to blocking enforcement.

DevSecOps Lead

1 L1

Explain the difference between an SBOM and SLSA provenance, and why you need both.

Listen for: the "ingredient list vs. food safety certification" distinction — SBOM says what's inside, SLSA proves how/where it was built. A candidate who treats them as interchangeable doesn't understand supply-chain assurance.

2 L2

Why would you choose keyless attestation over key-based signing, and what's the actual mechanism that makes it safe?

Listen for: OIDC-based workload identity → Fulcio issues a short-lived cert → Cosign signs → key discarded immediately. The point isn't "no keys exist," it's that no long-lived key ever needs custody, rotation, or leak-risk management.

3 L3

Leadership wants to claim SLSA Level 3 compliance across the whole estate, including the air-gapped environment. What do you tell them?

Listen for: direct pushback with the actual constraint — Level 3 requires Harness-hosted, per-run ephemeral build infrastructure, which is unavailable in Self-Managed/air-gapped deployments. A candidate who says "sure, we'll figure it out" either doesn't know this constraint or is avoiding a hard conversation — both are red flags for this role.

4 L2

A new zero-day is disclosed in a widely-used open-source package. Walk me through your response using the tooling available.

Listen for: search SBOMs across the estate for the affected component (by name/PURL), block it going forward via OPA policy on new builds, and open remediation tracking for existing artifacts — distinguishing "stop the bleeding" from "clean up the backlog" as two different actions with different urgency.

5 L3

The platform team wants to pilot an AI agent that can auto-remediate flaky tests and open PRs. What governance do you require before it touches anything beyond a feature branch?

Listen for: scoped per-agent identity/credentials (not inheriting the invoking pipeline's full permission set), the same approval gates and audit trail that govern human-triggered production changes, and — ideally — awareness of the "approval fatigue" problem (rubber-stamping ~93% of prompts) as a reason per-action approval alone isn't sufficient; a risk-tiered gate is the more defensible design. A candidate who says "just let it run, we'll monitor it" hasn't internalized excessive-agency risk (OWASP LLM06).

6

L1

Where should secrets live: in the CI/CD tool's built-in secret store, or in an external secrets manager? Why?

Listen for: external manager (Vault/cloud-native KMS) as the default for anything beyond a proof of concept, OIDC-based short-lived auth to that manager rather than static credentials, and awareness that built-in secret stores are a reasonable starting point but not the enterprise answer.

This closes the scoped treatment of the original research prompt. Remaining unaddressed sections — per-industry reference architecture diagrams, the 15 hands-on labs, and formal sequence diagrams — are documentation-generation exercises rather than research findings; say the word if you'd like any of those specifically rather than the full set.